GESTIÓN DE INCIDENTES DE SEGURIDAD INFORMÁTICA

MF0488_3

UNIDAD DIDÁCTICA 1

Sistemas de Detección y Prevención de Intrusiones (IDS/IPS)

Certificado de Profesionalidad
Seguridad Informática (IFCT0109)

Versión 1.0 · Curso 2024-2025

1. Conceptos Generales de Gestión de Incidentes

La gestión de incidentes de seguridad constituye el pilar fundamental de cualquier estrategia defensiva moderna. Comprende el conjunto de procesos, procedimientos y tecnologías destinados a detectar, analizar, contener y recuperarse de eventos adversos que puedan comprometer la seguridad de los sistemas de información.

1.1 ¿Qué es la Gestión de Incidentes de Seguridad?

Según el estándar NIST SP 800-61r2, un incidente de seguridad informática se define como una violación o amenaza inminente de violación de las políticas de seguridad informática, las políticas de uso aceptable o las prácticas de seguridad estándar.

Los objetivos principales de la gestión de incidentes son:

- Detectar amenazas o ataques antes de que causen daño irreparable
- Analizar el alcance e impacto real del incidente
- Responder de forma rápida, coordinada y efectiva
- Recuperar los sistemas afectados al estado operativo normal
- Documentar el incidente para mejorar futuras respuestas (lecciones aprendidas)

La Tríada CIA — Base de la Seguridad de la Información

Un incidente de seguridad es cualquier evento que comprometa uno o más pilares de la tríada CIA:

- **Confidencialidad:** La información solo debe ser accesible por entidades autorizadas. Ejemplo: filtración de credenciales de acceso a una base de datos.
- **Integridad:** La información no debe ser alterada sin autorización. Ejemplo: modificación no autorizada de registros médicos.
- **Disponibilidad:** Los sistemas deben estar operativos cuando se necesiten. Ejemplo: ataque DDoS que deja inaccesible un portal web.

1.2 El Ciclo de Vida de un Incidente de Seguridad

El NIST define cuatro fases en el ciclo de vida de un incidente:

Fase	Actividades Clave	Herramientas Típicas
1. Preparación	Definir políticas, formar equipos CSIRT, configurar herramientas de monitorización	IDS/IPS, SIEM, Playbooks
2. Detección y Análisis	Identificar indicadores de compromiso, correlacionar eventos, clasificar gravedad	Snort, Suricata, Splunk, Wireshark
3. Contención y Erradicación	Aislar sistemas afectados, eliminar malware, aplicar parches	Firewalls, EDR, Antivirus
4. Recuperación y Post-Incidente	Restaurar servicios, validar integridad, documentar lecciones aprendidas	Backups, Informes forenses

1.3 Detección de Intrusiones

La detección de intrusiones es el proceso de monitorización continua de sistemas y redes para identificar actividades sospechosas, no autorizadas o maliciosas. Se basa en dos enfoques complementarios:

- **Detección por firmas:** Compara el tráfico o comportamiento observado con una base de datos de patrones conocidos de ataques (signatures). Es rápida y precisa para amenazas conocidas.
- **Detección por anomalías:** Establece un perfil de comportamiento normal (baseline) y genera alertas cuando se detectan desviaciones significativas. Puede identificar amenazas desconocidas (zero-days).

Ejemplo Práctico — Detección de Escaneo de Puertos

Escenario: Un atacante realiza un escaneo Nmap desde 192.168.1.100 contra un servidor web.

Detección por firma: El IDS reconoce el patrón de paquetes SYN a múltiples puertos en secuencia rápida como firma de escaneo SYN scan (Nmap).

Detección por anomalía: El baseline indica que el servidor recibe ~5 conexiones/minuto. De repente recibe 500 intentos de conexión en 10 segundos → desviación estadística → alerta.

1.4 Prevención de Intrusiones

Mientras que un IDS adopta una postura pasiva (observar y alertar), un IPS actúa activamente para bloquear o mitigar ataques en tiempo real. Para ello, se sitúa inline en el flujo de tráfico de red, con capacidad para:

- Descartar paquetes maliciosos antes de que lleguen al destino
- Cerrar sesiones TCP activas mediante paquetes RST
- Bloquear dinámicamente IPs atacantes en el firewall
- Limitar el ancho de banda de tráfico sospechoso
- Generar alertas y registros detallados del incidente bloqueado

1.5 Comparativa IDS vs IPS

Característica	IDS (Intrusion Detection System)	IPS (Intrusion Prevention System)
Función principal	Detectar y alertar	Detectar, alertar y bloquear
Acción ante ataque	Genera alerta — requiere intervención humana	Actúa automáticamente en tiempo real
Posición en red	Fuera del flujo (tap/span port)	En línea con el tráfico (inline)
Latencia	No introduce latencia en el tráfico	Introduce latencia mínima por procesamiento
Riesgo de falsos positivos	Genera alertas falsas (sin impacto)	Puede bloquear tráfico legítimo
Caso de uso ideal	Auditoría, análisis forense, entornos sensibles	Bloqueo automático, entornos de producción
Ejemplo de herramienta	Snort (modo IDS), Suricata (modo pasivo)	Snort inline, Suricata (IPS), Cisco Firepower

2. Identificación y Caracterización de Datos del Sistema

Para que un sistema IDS/IPS funcione eficazmente, es imprescindible conocer a fondo el comportamiento normal del sistema que se va a proteger. Sin esta base de referencia, es imposible distinguir entre actividad legítima y maliciosa.

2.1 Tipos de Datos Analizados

Tipo de Dato	Descripción	Ejemplo Práctico
Tráfico de red	Paquetes, protocolos, flujos TCP/UDP, cabeceras IP	Wireshark captura tráfico ICMP flood → posible DoS
Logs del sistema	Registros de eventos del SO, aplicaciones, servicios	Windows Event ID 4625 → múltiples fallos de login
Actividad de usuarios	Comandos ejecutados, accesos a ficheros, cambios de configuración	Usuario accede a /etc/shadow fuera de horario laboral
Uso de recursos	CPU, memoria RAM, ancho de banda, disco	CPU al 100% durante horas → posible cryptominer
Conexiones de red	IPs origen/destino, puertos, duración de sesiones	Conexión saliente a IP en lista negra (threat intel)
Integridad de ficheros	Hash de ficheros críticos del sistema	Cambio en hash de /bin/bash → posible rootkit

2.2 La Línea Base (Baseline)

La línea base o baseline es la fotografía del comportamiento normal del sistema durante un período de observación estable. Se construye midiendo métricas clave durante un tiempo representativo (habitualmente 2-4 semanas) y sirve como referencia para detectar anomalías.

Ejemplo de Baseline para un Servidor Web Apache

Período de medición: 3 semanas en producción normal

- Peticiones HTTP/hora: media 2.500, máximo histórico 8.000
- Ancho de banda entrante: media 15 Mbps, pico 40 Mbps
- Conexiones simultáneas: media 120, máximo 350
- Tiempo de respuesta medio: 180 ms
- Tasa de errores 4xx/5xx: < 2%

Alerta por anomalía: Si se detectan 50.000 peticiones/hora, el IDS genera alerta de posible ataque DDoS HTTP Flood (desviación 6x sobre el máximo histórico).

2.3 Indicadores de Compromiso (IoC)

Los Indicadores de Compromiso (Indicators of Compromise, IoC) son artefactos forenses observables en una red o sistema que indican con alta probabilidad la presencia de actividad maliciosa. Son fundamentales para la detección basada en inteligencia de amenazas (Threat Intelligence).

Clasificación de IoCs según el modelo de la Pirámide del Dolor (D. Bianco):

Tipo de IoC	Ejemplo	Dificultad para el Atacante de Cambiar
Hash de fichero	MD5: d41d8cd98f00b204e9800998ecf8427e (fichero vacío)	Muy fácil — un bit cambia el hash
Dirección IP	192.168.1.100, 185.220.101.47 (Tor exit node)	Fácil — cambian de IP frecuentemente
Dominio/URL	malware-c2.xyz/beacon, update.micros0ft.com	Moderada — requiere registrar nuevo dominio
Artefacto de red	User-Agent: Mozilla/5.0 (compatible; Googlebot/2.1)	Moderada — puede cambiar cabeceras
Herramientas	Mimikatz, Cobalt Strike, Metasploit	Difícil — requiere reescribir el malware
TTPs (MITRE ATT&CK)	Técnica T1055 (Process Injection), T1003 (Credential Dumping)	Muy difícil — cambia el modus operandi completo

🔍 Ejemplo Práctico — Análisis de IoCs con Splunk

Escenario: Analista de seguridad recibe alerta de posible infección por Emotet.

Búsqueda en Splunk para correlacionar IoCs conocidos:

```
# Búsqueda SPL para detectar IoCs de Emotet en logs de red
index=network_logs
| search dest_ip IN ("185.220.101.47","45.33.32.156","198.51.100.23")
   OR dest_port IN (8080, 8443, 4444)
   OR url_domain IN ("malware-c2.xyz","emotet-update.net")
| stats count by src_ip, dest_ip, dest_port, url_domain
| sort -count
| table src_ip dest_ip dest_port url_domain count
```

Resultado: Si una IP interna aparece con múltiples conexiones a IPs de la lista negra → posible host comprometido → abrir incidente P1.

3. Arquitecturas de Sistemas IDS

La elección de la arquitectura adecuada depende del entorno a proteger, el volumen de tráfico, los recursos disponibles y los objetivos de seguridad. Las tres arquitecturas principales son NIDS, HIDS y los sistemas híbridos.

3.1 NIDS — Network Intrusion Detection System

Un NIDS monitoriza el tráfico de red en tiempo real, analizando los paquetes que circulan por los segmentos de red protegidos. Se ubica en puntos estratégicos como switches de distribución o routers de frontera, capturando tráfico mediante port mirroring (SPAN) o TAPs de red.

Arquitectura NIDS con Suricata

Componentes típicos de un despliegue NIDS:

- Sensor NIDS: Servidor con Suricata/Snort conectado al puerto SPAN del switch core
- Motor de análisis: Procesa paquetes contra ruleset (Emerging Threats, VRT Snort Rules)
- Gestor de alertas: Envía alertas a SIEM (Splunk, ELK Stack) vía syslog
- Consola de gestión: Dashboard en tiempo real (Security Onion, Kibana)

```
# Ejemplo de regla Suricata (NIDS) para detectar escaneo Nmap SYN
alert tcp any any -> $HOME_NET any (
  msg:"SCAN Nmap SYN scan detected";
  flags:S,12;
  threshold: type both, track by_src, count 20, seconds 1;
  classtype:network-scan;
  sid:1000001; rev:1;
)
```

Ventajas NIDS	Limitaciones NIDS
Visión global del tráfico de toda la red	No puede analizar tráfico cifrado (HTTPS/TLS) sin SSL inspection
No consume recursos de los hosts monitorizados	En redes de alta velocidad puede perder paquetes (packet drop)
Transparente para los sistemas protegidos	No detecta ataques locales (malware sin tráfico de red)
Detecta ataques entre sistemas de la misma red	Requiere hardware potente en redes de alta velocidad (10G+)

3.2 HIDS — Host Intrusion Detection System

Un HIDS se instala directamente en el host a proteger (servidor, estación de trabajo, VM) y monitoriza la actividad interna: llamadas al sistema, acceso a ficheros, cambios en el registro, logs del SO y actividad de procesos.

Ejemplo: OSSEC/Wazuh como HIDS

Wazuh (evolución open-source de OSSEC) es el HIDS más utilizado en entornos empresariales. Su arquitectura incluye:

- Agente Wazuh: Instalado en cada host, recopila logs y datos de integridad
- Manager Wazuh: Centraliza y correlaciona eventos de todos los agentes
- Elasticsearch + Kibana (ELK): Almacenamiento y visualización de alertas
- FIM (File Integrity Monitoring): Detecta cambios no autorizados en ficheros críticos

```
# Regla Wazuh (HIDS) para detectar escalada de privilegios con sudo
<rule id='5401' level='10'>
  <if_sid>5400</if_sid>
  <match>sudo: authentication failure</match>
  <description>Failed sudo attempt - possible privilege
escalation</description>
  <group>authentication_failed,sudo,</group>
</rule>

# Verificar integridad de ficheros críticos (syscheck)
# En /var/ossec/etc/ossec.conf:
<syscheck>
  <frequency>3600</frequency>
  <directories check_all='yes'
report_changes='yes'>/etc,/usr/bin,/sbin</directories>
</syscheck>
```

Ventajas HIDS	Limitaciones HIDS
Detecta ataques locales sin tráfico de red	Consume CPU y memoria del host monitorizado
Analiza tráfico cifrado (ve datos descifrados en el host)	Si el host es comprometido, el HIDS puede ser desactivado
Monitoriza integridad de ficheros del sistema	Gestión compleja en entornos con muchos hosts
Detecta rootkits y malware residente	Cobertura limitada a un solo host

3.3 Sistemas Híbridos: Correlación NIDS + HIDS

Los sistemas híbridos combinan la visibilidad de red del NIDS con el análisis profundo del host del HIDS, ofreciendo la mayor cobertura posible. La correlación de eventos de ambas fuentes permite detectar ataques complejos que ningún sistema individual podría identificar.

Caso de Uso: Detección de APT con Arquitectura Híbrida

Escenario de ataque en múltiples fases (APT — Advanced Persistent Threat):

- **Fase 1 (Reconocimiento):** NIDS detecta escaneo de puertos desde IP externa → alerta baja prioridad.
- **Fase 2 (Intrusión inicial):** NIDS detecta exploit contra Apache → alerta media. HIDS detecta creación de proceso shell hijo de Apache → alerta alta.
- **Fase 3 (Movimiento lateral):** HIDS detecta acceso a /etc/shadow. NIDS detecta conexiones SMB internas anómalas.
- **Fase 4 (Exfiltración):** NIDS detecta transferencia de datos voluminosa a IP externa no habitual.

El SIEM correlaciona todos estos eventos y genera una alerta de incidente crítico con el contexto completo del ataque.

4. Tipos de IDS/IPS según Funcionalidad

Además de la clasificación por ubicación (NIDS/HIDS), los sistemas IDS/IPS se clasifican según el método de detección que emplean. Cada método tiene sus fortalezas y debilidades, y los sistemas modernos suelen combinar varios enfoques.

4.1 Detección Basada en Firmas (Signature-Based)

Es el método más extendido. El sistema mantiene una base de datos de firmas (patrones) que describen ataques conocidos. Cada paquete o evento se compara contra esta base de datos. Si coincide, se genera una alerta.

Anatomía de una Firma Snort/Suricata

Las firmas siguen la estructura: acción protocolo red_origen puerto_origen → red_destino puerto_destino (opciones)

```
# Firma para detectar intento de explotar EternalBlue (MS17-010 / WannaCry)
alert tcp $EXTERNAL_NET any -> $HOME_NET 445 (
  msg:"ET EXPLOIT EternalBlue SMB Remote Code Execution";
  flow:to_server,established;
  content:"|ff|SMB"; depth:8; offset:4;
  content:"Trans2"; distance:0;
  content:"|00 00 00 00 00 00 00 00 00 00 00 00|"; distance:0;
  reference:cve,2017-0144;
  classtype:attempted-admin;
  sid:2024218; rev:3;
)
```

Ventajas	Limitaciones
Alta precisión para ataques conocidos	No detecta ataques nuevos (zero-days)
Muy baja tasa de falsos positivos	Requiere actualización continua de firmas (reglas)
Procesamiento rápido y eficiente	Un cambio mínimo en el exploit puede evadir la firma
Fácil de entender y auditar	Base de datos de firmas puede ser muy voluminosa

4.2 Detección Basada en Anomalías (Anomaly-Based)

Construye un modelo estadístico o matemático del comportamiento normal del sistema (baseline) y genera alertas cuando el comportamiento observado se desvía significativamente de ese modelo. Es el único método capaz de detectar amenazas desconocidas.

Técnicas de Detección de Anomalías

- **Estadística:** Monitoriza medias, desviaciones estándar y distribuciones. Alerta si una métrica supera X desviaciones estándar sobre la media.
- **Machine Learning supervisado:** Modelos entrenados con tráfico normal y malicioso etiquetado (Random Forest, SVM, Redes Neuronales).
- **Machine Learning no supervisado:** Clustering (K-means, DBSCAN) para agrupar comportamientos. Los puntos alejados de los clusters son anomalías.

- **Análisis de comportamiento de usuario (UEBA):** Perfila el comportamiento típico de cada usuario y alerta ante desviaciones (accesos fuera de horario, volumen inusual de datos).

📊 Ejemplo: Detección de Exfiltración con Análisis de Anomalías

Baseline establecido para servidor de RRHH:

- Transferencia saliente media: 50 MB/día
- Destinos habituales: servidores internos, Office 365, Dropbox corporativo

Evento detectado: El servidor transfiere 8 GB a mega.nz a las 02:00 AM.

Alerta generada: Transferencia 160x sobre la media a destino no habitual en horario no laboral → POSIBLE EXFILTRACIÓN DE DATOS → Incidente P1.

4.3 Detección Basada en Políticas (Policy-Based)

Se define explícitamente qué comportamientos son permitidos o prohibidos mediante políticas de seguridad. El sistema genera alertas cuando se viola alguna política, independientemente de si el evento parece un ataque conocido o una anomalía estadística.

```
# Ejemplo: Política de seguridad en Suricata — Bloquear protocolos no
autorizados

# Política: Solo se permite tráfico web (HTTP/HTTPS) y DNS saliente
# Bloquear cualquier otro protocolo hacia Internet

drop tcp $HOME_NET any -> $EXTERNAL_NET !80 (
  msg:"POLICY Outbound non-HTTP TCP blocked";
  flow:to_server;
  sid:9000001; rev:1;
)

drop udp $HOME_NET any -> $EXTERNAL_NET !53 (
  msg:"POLICY Outbound non-DNS UDP blocked";
  sid:9000002; rev:1;
)
```

4.4 Comparativa de Métodos de Detección

Criterio	Firmas	Anomalías	Políticas
Detección de ataques conocidos	Excelente	Buena	Limitada
Detección de zero-days	Nula	Excelente	Parcial
Tasa de falsos positivos	Muy baja	Alta (requiere ajuste)	Baja
Mantenimiento requerido	Actualización frecuente de firmas	Recalibración periódica del modelo	Revisión de políticas
Capacidad de explicación	Alta (regla específica)	Baja (modelo estadístico)	Alta (política violada)
Herramienta ejemplo	Snort, Suricata, Cisco IPS	Darktrace, Vectra AI, UEBA	Palo Alto NGFW, Fortinet

5. Criterios de Seguridad para la Ubicación de IDS/IPS

La correcta ubicación de los sensores IDS/IPS es tan importante como la herramienta en sí. Un sensor mal ubicado puede ofrecer una falsa sensación de seguridad, monitorizar tráfico irrelevante o perderse los ataques más críticos.

5.1 Modelo de Zonas de Seguridad

Una arquitectura de red empresarial se divide habitualmente en zonas de seguridad, cada una con su nivel de confianza y requisitos de monitorización específicos:

Zona de Red	Descripción	Tipo de Sensor Recomendado
Internet / WAN	Red exterior, no confiable. Todo el tráfico entrante/saliente.	NIPS en perímetro (bloqueo de ataques externos)
DMZ (zona desmilitarizada)	Servidores accesibles desde Internet: web, correo, DNS.	NIDS + HIDS en servidores DMZ
Red corporativa interna	Usuarios, estaciones de trabajo, aplicaciones internas.	NIDS en core switch + HIDS selectivo
VLAN servidores críticos	Bases de datos, ERP, directorio activo.	NIPS inline + HIDS en cada servidor
Zona industrial (OT/SCADA)	Sistemas de control industrial (si aplica).	IDS especializado OT (Claroty, Nozomi)

5.2 Ubicaciones Estratégicas Recomendadas

Sensor 1: Perímetro Externo (Post-Firewall)

Ubicación: Entre el firewall de perímetro e Internet.

Objetivo: Detectar ataques que llegan del exterior ANTES de que el firewall los procese. Útil para auditoría y threat intelligence.

Alternativa: Algunos equipos NGFW integran IPS directamente (Palo Alto, Fortinet FortiGate).

Sensor 2: DMZ

Ubicación: En el segmento de red de la DMZ, monitorizando el tráfico hacia/desde los servidores públicos.

Objetivo: Detectar intentos de explotación de servicios web, ataques de inyección SQL, escaneos de vulnerabilidades.

Ejemplo: Suricata en modo NIDS conectado al puerto SPAN del switch de la DMZ.

Sensor 3: Red Interna / Core Switch

Ubicación: Puerto SPAN del switch de core de la red interna.

Objetivo: Detectar amenazas internas, movimiento lateral de atacantes, infecciones de malware propagándose por la red.

Importancia: El 60% de los incidentes tienen origen interno (empleados malintencionados, credenciales comprometidas).

Sensor 4: Segmento de Servidores Críticos

Ubicación: NIPS inline entre la red interna y el VLAN de servidores críticos (BBDD, AD, ERP).

Objetivo: Última línea de defensa antes de los activos más valiosos. Bloqueo activo de ataques laterales.

Complemento: HIDS (Wazuh) instalado en cada servidor crítico para monitorización del host.

5.3 Consideraciones Técnicas para la Ubicación

Factor	Consideración	Impacto si se ignora
Volumen de tráfico	El sensor debe procesar todo el tráfico sin pérdidas (packet drop < 0,1%)	Pérdida de visibilidad, ataques no detectados
Tráfico cifrado	TLS 1.3 impide la inspección sin SSL/TLS interception (proxy)	IDS ciego ante tráfico HTTPS/SFTP
Alta disponibilidad	El NIPS inline debe soportar bypass hardware si el sensor falla	Corte de tráfico de producción
Redundancia de red	En topologías con múltiples rutas, colocar sensores en todos los caminos	Tráfico que evita el sensor pasa sin inspección
Segmentación VLAN	Colocar sensores por VLAN o usar reflectores de tráfico (RSPAN/ERSPAN)	Visibilidad parcial en redes segmentadas

5.4 Errores Comunes en la Implementación

⚠ Errores Frecuentes y Cómo Evitarlos

- **Error 1 — Un único sensor para toda la red:** Colocar un solo NIDS en el perímetro deja ciegos los movimientos laterales internos. Solución: arquitectura en capas con sensores en cada zona.
- **Error 2 — No actualizar las firmas:** Las firmas desactualizadas no detectan vulnerabilidades recientes. Implementar actualizaciones automáticas diarias (suricata-update, PulledPork).
- **Error 3 — No revisar las alertas:** Un IDS que genera 10.000 alertas/día y nadie revisa es inútil. Implementar SIEM con correlación y priorización automática.
- **Error 4 — Ignorar los falsos positivos:** Un volumen alto de falsos positivos genera alert fatigue. Ajustar el ruleset regularmente y whitelistear tráfico legítimo conocido.
- **Error 5 — IPS sin plan de contingencia:** Un IPS que bloquea tráfico legítimo puede cortar servicios críticos. Configurar bypass hardware y probar las reglas en modo IDS primero.

5.5 Caso Práctico: Diseño de Arquitectura IDS/IPS para PYME

Escenario: Empresa de 150 empleados, con servidores web y correo en DMZ, base de datos Oracle con datos personales (sujeta a RGPD) y usuarios en oficina.

Arquitectura Propuesta

- Sensor 1 (NIPS): Fortinet FortiGate 60F con IPS activado — perímetro Internet/WAN
- Sensor 2 (NIDS): Suricata en Security Onion — monitorización DMZ (web, correo)
- Sensor 3 (NIDS): Suricata segunda instancia — core switch de red interna
- Sensor 4 (HIDS): Wazuh Manager + agentes en todos los servidores Linux/Windows
- SIEM: Wazuh + Elasticsearch + Kibana para correlación centralizada
- Threat Intelligence: Integración con feeds MISP y Emerging Threats

```
# Despliegue rápido de Security Onion (NIDS) en VMware
# Requisitos: 4 vCPU, 8 GB RAM, 100 GB disco, 2 interfaces de red

# 1. Descargar ISO de Security Onion 2.4
wget https://github.com/Security-Onion-Solutions/securityonion/releases/latest

# 2. Tras instalación, configurar interfaz de monitorización (sin IP)
sudo so-setup
# Seleccionar: Import / Eval / Production
# Interfaz de gestión: eth0 (con IP)
# Interfaz de captura: eth1 (sin IP, en modo promiscuo)

# 3. Verificar que Suricata está capturando
sudo so-suricata-restart
sudo tail -f /nsm/suricata/logs/eve.json | python3 -m json.tool
```

6. Herramientas IDS/IPS: Snort y Suricata

Snort y Suricata son los sistemas IDS/IPS open-source más utilizados en el mundo. Snort fue el pionero (1998, Martin Roesch) y Suricata su evolución moderna con soporte multihilo nativo. Ambas utilizan un formato de reglas compatible.

6.1 Snort 3 — Configuración Básica

```
# Instalación de Snort 3 en Ubuntu 22.04
sudo apt update && sudo apt install -y snort3

# Configuración mínima /etc/snort/snort.lua
-- Definir redes a proteger
HOME_NET = '192.168.0.0/16,10.0.0.0/8'
EXTERNAL_NET = '!$HOME_NET'

-- Activar módulos de detección
detection = { hyperscan = true }

-- Habilitar salida de alertas en formato unified2
alert_fast = { file = true }

# Ejecutar Snort en modo IDS (escucha en eth1)
sudo snort -c /etc/snort/snort.lua -i eth1 -A alert_fast

# Probar regla personalizada
echo 'alert icmp any any -> any any (msg:"ICMP Test"; sid:999999;)' >
/etc/snort/rules/local.rules
sudo snort -c /etc/snort/snort.lua -i eth1 -R /etc/snort/rules/local.rules
```

6.2 Suricata — Modo IDS e IPS

```
# Instalación de Suricata en Ubuntu 22.04
sudo add-apt-repository ppa:oisf/suricata-stable
sudo apt install suricata -y

# Actualizar reglas con suricata-update
sudo suricata-update
sudo suricata-update update-sources
sudo suricata-update enable-source et/open   # Emerging Threats Open

# Modo IDS — captura pasiva en eth1
sudo suricata -c /etc/suricata/suricata.yaml -i eth1

# Modo IPS inline con NFQueue (requiere regla iptables)
sudo iptables -I FORWARD -j NFQUEUE --queue-num 0
sudo suricata -c /etc/suricata/suricata.yaml -q 0

# Ver alertas en tiempo real
sudo tail -f /var/log/suricata/fast.log
sudo tail -f /var/log/suricata/eve.json | jq 'select(.event_type=="alert")'
```

7. Conclusiones

Los sistemas IDS/IPS representan un componente esencial de la defensa en profundidad (Defense in Depth) en cualquier infraestructura tecnológica moderna. Su valor no reside únicamente en la detección o bloqueo de ataques, sino en la visibilidad que proporcionan sobre el estado de seguridad de la organización.

7.1 Principios Clave

Principio	Descripción	Consecuencia si se viola
Ubicación estratégica	Los sensores deben cubrir todas las zonas de seguridad críticas	Puntos ciegos en la red
Actualización continua	Firmas, reglas y software deben mantenerse actualizados	Vulnerabilidades conocidas sin detectar
Análisis proactivo	Las alertas deben revisarse y correlacionarse regularmente	Alert fatigue y ataques no detectados
Ajuste periódico	El ruleset debe afinarse para reducir falsos positivos	Bloqueo de tráfico legítimo
Integración con SIEM	Los eventos deben centralizarse y correlacionarse	Visión fragmentada del estado de seguridad

✓ Resumen de Capacidades por Tipo de Sistema

La elección entre IDS e IPS, y entre los distintos métodos de detección, debe hacerse en función de los objetivos de seguridad, los recursos disponibles y el nivel de riesgo aceptable:

- **IDS:** Ideal para entornos donde se prioriza la visibilidad y el análisis forense sin riesgo de corte de servicio.
- **IPS:** Ideal para entornos de producción que requieren respuesta automática y bloqueo de amenazas en tiempo real.
- **NIDS/NIPS:** Cobertura global de la red; limitados con tráfico cifrado.
- **HIDS:** Máxima visibilidad del host; complementario al NIDS.
- **Firmas:** Alta precisión para amenazas conocidas; requiere actualización continua.
- **Anomalías + ML:** Detecta zero-days y amenazas internas; requiere calibración y genera más falsos positivos.

En última instancia, la eficacia de cualquier sistema IDS/IPS depende en mayor medida de las personas y los procesos que lo gestionan que de la tecnología en sí. Un analista de seguridad bien formado con herramientas básicas es más eficaz que una plataforma costosa sin personal cualificado.

Fin de la Unidad Didáctica 1 — MF0488_3 · Gestión de Incidentes de Seguridad Informática